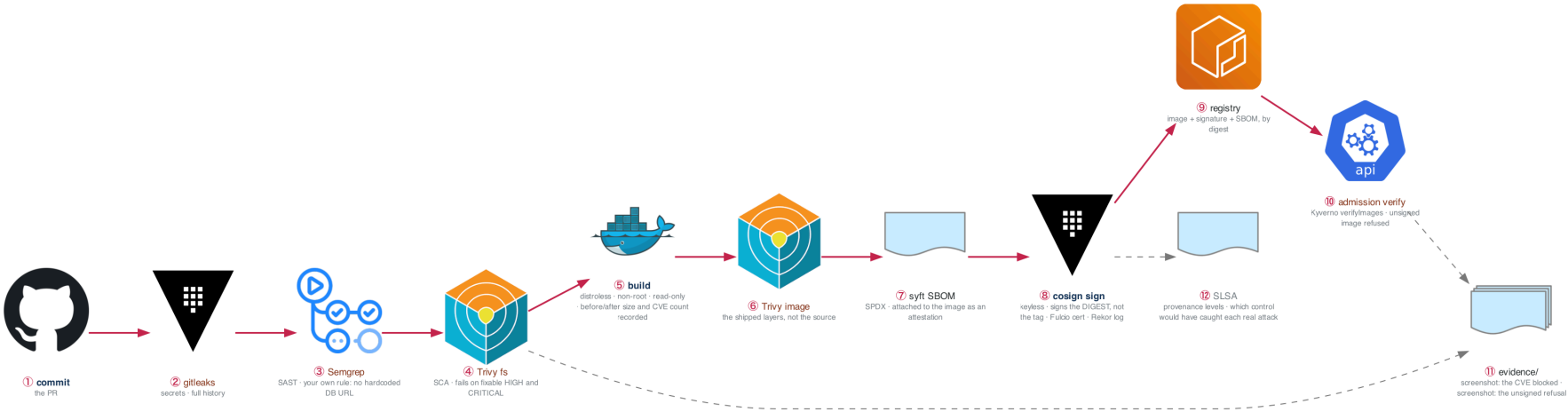
The pipeline that refuses, numbered

Week 18 · Figure 18.1 · figure with badges 1–12 · 2026-10-17



What to say, badge by badge

About four minutes at a normal pace (459 words). Point at each badge as you say its line.

Open
“Almost no candidate at this level can talk credibly about supply chain security, and hiring managers have been told to care since Log4Shell. This is a pipeline that refuses, and the two refusals come with screenshots. Follow the line; stop at every orange box.”

1 commit
“A pull request opens. Everything to the right runs before a human looks at it, and the cheapest checks run first so a leaked key fails in seconds, not after a ten-minute build.”

2 gitleaks
“Secrets, scanned across the full history, because a key deleted in the next commit is still in the repository. The same binary, the same version, runs in the pre-commit hook and in CI.”

3 Semgrep
“Static analysis on the source. You write one rule yourself, no hardcoded database URL, so you understand that a scanner is a pattern someone chose, not an oracle.”

4 Trivy on the filesystem
“Dependency scanning against the lockfiles. The gate fails on fixable HIGH and CRITICAL. Fixable is the key word: an unfixable finding goes to an exception with an expiry and an owner, which is the week-19 control narrative.”

5 build
“Distroless base, non-root user, read-only filesystem. Measure the image size and CVE count before and after and write both numbers down. No shell in the image means no `kubectl exec sh`, for you and for an attacker.”

6 Trivy on the image
“Scan what ships, not what you compiled from. Base image CVEs live here, and they are most of the count.”

7 syft SBOM
“A software bill of materials in SPDX, attached to the image as an attestation. When the next Log4Shell lands, this is how you answer 'are we affected' in minutes instead of days.”

8 cosign sign
“Keyless: the workflow's OIDC identity gets a short-lived certificate from Fulcio, the signature is recorded in the Rekor transparency log, and what is signed is the digest. A tag can be moved; a digest cannot.”

9 registry
“The image, its signature, and its SBOM, all addressed by digest. Pulling by tag is convenience; verifying by digest is the control.”

10 admission verify
“Kyverno's verifyImages checks the signature at admission against the expected identity. An unsigned image, or one signed by the wrong workflow, is refused before it runs. Push one on purpose and capture the refusal.”

11 evidence
“Two screenshots in the repository: a deliberately introduced critical CVE blocking the build, and an unsigned image refused at admission. Evidence is what separates a control from a claim, and Gate 5 asks for it live.”

12 SLSA
“The provenance levels give you vocabulary: who built it, from what, on what builder, with what guarantees. Thursday's case studies ask one question of each real attack: which of these boxes would have caught it.”

Close
“Scan the source, harden the build, scan the image, describe it, sign the digest, verify at the door. Then prove it twice with a screenshot. That is the month that beats other juniors.”